

Section 09



Industrial Security (Bachelor)

Section 09 – Standards, Compliance, Governance

Standards, Compliance, and Governance

Lecture Notes

Department of Computer Science

1 Standards

2 Regulations

3 Programme

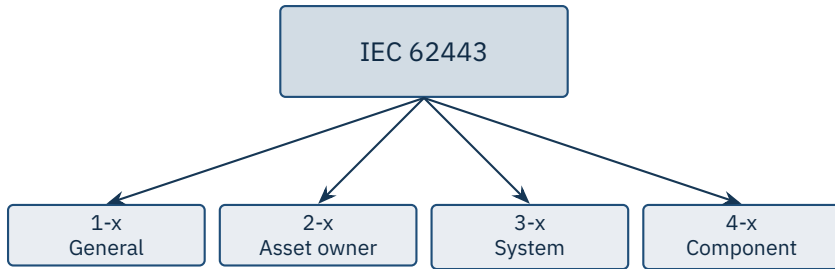
By the end of this section you will be able to

- Navigate the IEC 62443 family of standards.
- Understand the role of NIST CSF and NIST SP 800-82.
- Recognise major regulations: NIS2, KRITIS, NERC CIP, TSA, CIRCIA.
- Sketch the structure of an OT security programme.

1

Standards

Section 09 – Standards, Compliance, and Governance

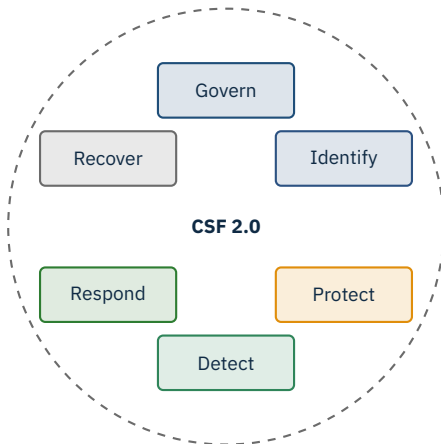


Source: IEC 62443 series (joint with ISA/IEC) | ISA-99 committee, ongoing.

SL 1	Casual / coincidental violation
SL 2	Simple, low-resource attacker
SL 3	Sophisticated, moderate resources
SL 4	Sophisticated, nation-state

Per-zone target

Each zone gets a target SL (SL-T) chosen by *consequence* and the expected *threat actor*.



Outcome-based, sector-neutral. NIST SP 800-82 Rev. 3 is the ICS-specific companion.

Source: NIST, Cybersecurity Framework 2.0, Feb 2024 | NIST SP 800-82 Rev. 3, Sep 2023.

2

Regulations

Section 09 – Standards, Compliance, and Governance

EU – NIS2

US – NERC CIP (electric)

DE – KRITIS, IT-SiG 2.0, BSI

US – TSA SD (pipelines)

EU – CRA

US – CIRCIA reporting

Sector: IEC 62443, IEC 61850, ANSI/ISA-84

Source: NIS2: Directive (EU) 2022/2555 | CRA: Regulation (EU) 2024/2847 | KRITIS: BSI-Kritisverordnung | NERC CIP-002–CIP-014.

3

Programme

Section 09 – Standards, Compliance, and Governance

1. Governance – charter, RACI, executive sponsor

2. Asset inventory – ground truth

3. Risk assessment – IEC 62443-3-2

4. Architecture – zones, conduits, segmentation

5. Controls – baseline per SL-T

6. Operations – patching, monitoring, IR

7. Training & awareness – engineers and IT

8. Measurement – KPIs, audits, lessons learned

Cybersecurity management system (CSMS) – the OT-side ISMS

Risk analysis, system architecture, security policies

Patch management, incident response, training

Supplier requirements (62443-2-4) and SDL (62443-4-1)

For asset owners

2-1 is the part you implement as a utility or operator. It is the auditable backbone.

Identification & authentication

Use control

Data integrity

Data confidentiality

Restricted data flow

Timely event response

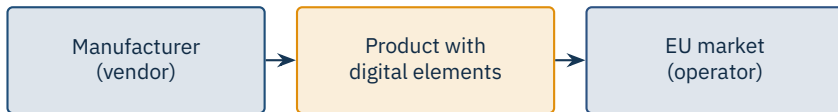
Resource availability

Seven Foundational Requirements (FRs), each refined into System Requirements (SRs) per SL.

- ICS-specific companion to NIST SP 800-53.
- Published 2023; mapping tables to IEC 62443 included.
- Tiered guidance: low / moderate / high impact systems.
- Strong focus on **safety** and **operational continuity** – not just confidentiality.

When to reach for it

US federal contractors, sector-CISA regulated entities, and any team that prefers outcome-based controls to a prescriptive standard.



New duties

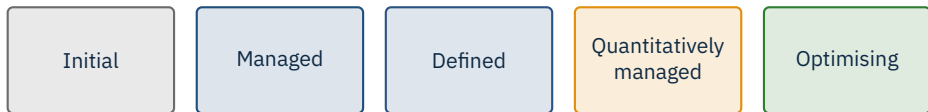
Manufacturers must provide security updates, vulnerability handling, and an SBOM. CE marking now covers cybersecurity too.

Source: Regulation (EU) 2024/2847 of the European Parliament and Council (Cyber Resilience Act), 23 Oct 2024.

- Risk-based, sector-tailored controls (energy, transport, water).
- Strong emphasis on *supply chain* obligations.
- Continuous monitoring (network + endpoint) for OT estates.
- Cross-border incident-information-sharing framework.

For EU operators

ENISA guidance is non-binding but shapes how national CERTs read NIS2 duties.



Common references: **C2M2** (DOE), **CMMC** (US DoD), and IEC 62443's own programme maturity.

- Up-to-date asset inventory with firmware versions
- Documented zones & conduits (preferably in a CMDB)
- Risk register with named owners and review dates
- Patch and change-management records
- Backup logs with restore-test evidence
- Incident-response playbooks plus a recent tabletop report
- Training attendance for operators and engineers

Tip

The first audit is hardest. Treat it as a baseline scan – gaps you find are not failures, they are your roadmap.

★ Key Takeaway: What to remember from this section

- IEC 62443 provides the engineering vocabulary; NIST CSF gives the outcomes language.
- Security Levels (SL 1–4) tie risk to required control rigor.
- Regulations now demand board-level accountability and incident reporting.
- A programme is governance, inventory, risk, architecture, controls, ops, training, measurement.

- IEC 62443 series. *Industrial communication networks – IT security for networks and systems* (joint ISA/IEC).
- NIST. *Cybersecurity Framework 2.0*, Feb 2024.
- Stouffer, K. et al. *NIST SP 800-82 Rev. 3 – Guide to OT Security*, Sep 2023.
- NIST SP 800-53 Rev. 5. *Security and Privacy Controls for Information Systems and Organizations*, 2020.
- Directive (EU) 2022/2555. *NIS2 Directive*, 14 Dec 2022.
- Regulation (EU) 2024/2847. *Cyber Resilience Act*, 23 Oct 2024.
- Germany BSI. *BSI-Kritisverordnung (BSI-KritisV) and IT-Sicherheitsgesetz 2.0*.
- ENISA. *Good practices for the security of IACS*, 2020 onwards.
- NERC. *CIP Reliability Standards*, CIP-002 through CIP-014.
- US TSA. *Pipeline / Rail Security Directives*, 2021 onwards.
- US CISA. *CIRCI Act – Cyber Incident Reporting for Critical Infrastructure Act*, in rule-making.
- DOE. *Cybersecurity Capability Maturity Model (C2M2)*, current.

End of Section 09

Standards, Compliance, and Governance

Questions and discussion